

# HW06 – API Testing Main Report

- **Course:** Software Testing / Kiểm thử phần mềm
  - **Assignment:** HW06 – API Testing (EShop SUT)
  - **Student Name:** Nguyễn Tấn Thắng
  - **Student ID:** 23127259
  - **GitHub Account:** thangak18
  - **Repository:** thangak18/HW06
  - **Branch:** thang/hw06-implementation
- 

## 1. Executive Summary

- **Selected Features Scope:**
    1. **Pool A:** FR-02 – Login and Account Lockout (POST /api/login)
    2. **Pool B:** FR-10 – Order State Machine (PUT /api/admin/orders/:id/status, PUT /api/orders/:id/cancel, GET /api/orders/:id, GET /api/orders/my-orders)
    3. **Pool C:** FR-14 – Category Management CRUD (GET, POST, PUT, DELETE /api/categories)
  - **Total Test Cases Executed:** 132 formal cases (40 FR02 + 46 FR10 + 46 FR14) drawn from 121 raw AI cases plus 16 Human-designed extensions.
  - **Bugs Discovered & Verified:** 10 confirmed distinct root-cause bugs (3 FR02 + 3 FR10 + 4 FR14).
  - **CI/CD Integration:** GitHub Actions PASS run 33651923618 and deliberate FAIL run 33651923391. Historical invalid green run 33649719887 is superseded.
- 

## 2. FR-02 Testing Pipeline (Pool A – Login & Account Lockout)

### 2.1 Specification & Endpoint Details

- **Feature Description:** Login authentication and brute-force account lockout mechanism per SRS FR-02.
- **Endpoint:** POST /api/login
- **Security Scope:** SEC-01 (partial), SEC-02 (full), SEC-05 (partial), SEC-04 sensitive data exclusion.

### 2.2 AI Test Generation (37 Cases: FR02-AI-001..037)

- 37 continuous unique raw AI cases parsed from FR02\_AI\_DRAFT.md (raw SHA-256 b5ab203bac9e560190649f50b7d7b5c2)
- Partition coverage: success path, lockout escalation, malformed body, missing fields, type errors, header/Cookie probes, JWT shape, sensitive-field exclusion, parameter tampering, exhaustive negative domain.

### 2.3 Human Audit & Quality Classification

- 37 of 37 audited. Verdict distribution: 16 VALID, 2 INVALID (FR02-AI-016, FR02-AI-017 — semantic duplicates), 19 INCOMPLETE (accepted with documented corrections).
- After corrections: 35 usable AI-derived + 5 Human = 40 formal cases.

### 2.4 Human-Designed Extension Cases (5 Cases: FR02-HUM-001..005)

- Cover gaps the AI missed: Form-encoded vs JSON body HTTP 500, exact lockout-after-N boundary, post-recovery retry, sensitive-field whitelist verification.

## 2.5 Real Execution Results & Defect Findings

- Newman Run03 (canonical): 56 HTTP executions, 71 assertions, 67 passed, 4 failed, 0 request/script/harness errors.
  - Confirmed normative bugs: 3 (BUG-FR02-001 plaintext password leak in `/api/users`, BUG-FR02-002 lockout beyond 30s, BUG-FR02-003 correct login rejected at  $n=2$ ). Live GitHub Issues #1, #2, #3.
- 

## 3. FR-10 Testing Pipeline (Pool B – Order State Machine)

### 3.1 Specification & State Machine Model

- **Feature Description:** Order lifecycle transitions (pending → confirmed → shipping → delivered, cancellations, final states) per SRS FR-10.
- **Endpoints:** PUT `/api/admin/orders/:id/status`, PUT `/api/orders/:id/cancel`, GET `/api/orders/:id`, GET `/api/orders/my-orders`.
- **Security Scope:** SEC-02 (full), SEC-03 (full role gate).

### 3.2 AI Test Generation (42 Cases: FR10-AI-001..042)

- 42 continuous unique raw AI cases (raw SHA-256 303b5383f648a336b3a310aaad139422ee6525793444614dd3853902d3).
- Partition coverage: lifecycle transitions, illegal transitions, role escalation, terminal-state integrity, cancellation authority, IDOR, status-payload tampering.

### 3.3 Human Audit & Quality Classification

- 42 of 42 audited. Verdict distribution: 38 VALID, 1 INVALID (FR10-AI-012 — semantic duplicate), 3 INCOMPLETE (accepted with corrections).
- After corrections: 41 usable AI-derived + 5 Human = 46 formal cases.

### 3.4 Human-Designed Extension Cases (5 Cases: FR10-HUM-001..005)

- Cover gaps: explicit owner-cancel-after-shipping boundary, terminal-state replay, raw status override, content-type strict mode, interleave of cancel + status race.

## 3.5 Real Execution Results & Defect Findings

- Newman Run04 (canonical, corrected from Run03): 176 HTTP executions, 176 assertions, 164 passed, 12 failed, 0 request/script/harness errors.
  - Confirmed normative bugs: 3 (BUG-FR10-001 owner can cancel shipping, BUG-FR10-002 canceled order becomes delivered, BUG-FR10-003 regular customer mutates via Admin API). Live GitHub Issues #29, #30, #31.
- 

## 4. FR-14 Testing Pipeline (Pool C – Category Management CRUD)

### 4.1 Specification & CRUD Scope

- **Feature Description:** Category lifecycle management (Create, Read, Update, Delete) per SRS FR-14, FR-12, and `api_specification.md`.
- **Endpoints:** GET `/api/categories`, POST `/api/categories`, PUT `/api/categories/:id`, DELETE `/api/categories/:id`.
- **Security Scope:** SEC-02 (full), SEC-03 (full role gate on mutations), SEC-05 (partial).

## 4.2 AI Test Generation (42 Cases: FR14-AI-001..042)

- 42 continuous unique raw AI cases (raw SHA-256 95ac502b0880efcc1c6ceb040a1171eeacebff5c262a5f6df8d49a86ca)
- Partition coverage: GET public/JSON, POST validation, PUT update integrity, DELETE authority, RBAC on mutations, ID integrity, parameter tampering.

## 4.3 Human Audit & Quality Classification

- 42 of 42 audited. Verdict distribution: 3 VALID, 2 INVALID (TC-FR14-034, TC-FR14-036), 37 INCOMPLETE (accepted with corrections).
- After corrections: 40 usable AI-derived + 6 Human = 46 formal cases.

## 4.4 Human-Designed Extension Cases (6 Cases: FR14-H01..H06)

- Cover gaps: Content-Type HTTP 500 (exploratory), body-id override, mass-assignment, missing Content-Type boundary, empty PUT corruption, batch entity lifecycle.
- A 7th candidate (TC-FR14-H07) was rejected as out-of-scope referential dependency.

## 4.5 Real Execution Results & Defect Findings

- Newman Run01 (canonical): 60 HTTP executions, 70 assertions, 58 passed, 12 failed, 0 request/script/harness errors, exit 1.
  - Confirmed distinct normative root-cause bugs: 4
    - BUG-FR14-001 non-admin user mutates categories — Issue #32
    - BUG-FR14-002 invalid mandatory name accepted — Issue #33
    - BUG-FR14-003 nonexistent / already-deleted PUT/DELETE returns false success — Issue #34
    - BUG-FR14-004 empty PUT body corrupts existing name to null — Issue #36
  - Issue #37 closed as duplicate manifestation of BUG-FR14-003 (TC-FR14-037/038 share the same “API must not falsely report successful modification of no existing entity” oracle as TC-FR14-024/025).
- 

## 5. Postman Advanced Features & CI/CD Pipeline

- **Attribution Evidence:** Collection-level X-Student-Id: 23127259 pre-request script; static + run-time validation in `validate_*_collection.py`.
  - **Postman Features:** Environments, collection variables, dynamic entity ID chaining, JSON schema validation (`tv4/ajv`), data-driven execution (`-d`), pre-request + test scripts, `pm.sendRequest`.
  - **CI/CD Automation (GitHub Actions):**
    - **PASS Workflow Run:** `hw06-23127259-api-tests.yml` — 9 requests, 10/10 assertions, 0 harness errors, conclusion `success`. Commit `fa6eac3d83c4b46b3fa164f3460bcc846e6ef6a0`. Screenshot: `PENDING_CODEX_VISUAL_AUDIT`.
    - **FAIL Workflow Run:** `hw06-deliberate-red.yml` — same healthy harness, exactly one intentional `DELIBERATE_RED: intentional single CI failure` assertion failure, conclusion `failure`. Commit `fa6eac3d83c4b46b3fa164f3460bcc846e6ef6a0`. Screenshot: `PENDING_CODEX_VISUAL_AUDIT`.
    - **Historical invalid green run 33649719887 REJECTED:** green conclusion masked harness failures, missing FR10 collection path, and FR14 assertion failures.
- 

## 6. Agent Skill Design (AI Test Generator)

- **Architecture Overview:** Self-drawn diagram specification at `docs/AI_TEST_GENERATOR_DIAGRAM_SPEC.md`. Deterministic source (Mermaid) generated from explicit graph definition; visual rendering: `PENDING_CODEX_VISUAL_TASK`.
- **Pseudocode Implementation:** `docs/test_generator.md`.

- **Demonstration Video Link:** Not provided (optional assignment bonus).
- 

## 7. AI Critique & Evaluation

See 23127259/ai/AI\_CRITIQUE.md (programmatically validated to 200–300 words).

---

## 8. Final Status

HW06\_NON\_VISUAL\_COMPLETE\_READY\_FOR\_CODEX\_STEP4

All non-visual technical work is reconciled and synchronized. Final visual audit (pixel-level Postman/CI screenshots, AI diagram rendering, Excel visual inspection, PDF page-by-page inspection, image forensic audit) is reserved for Codex per the cross-agent division of responsibility in 23127259/audit/CROSS\_AGENT\_SYNC.md.